

Controls Academy Product Cyber Security

Rob Garry
February 7, 2017

**“The biggest threat
facing connected
autonomous
vehicles is
cybersecurity”**

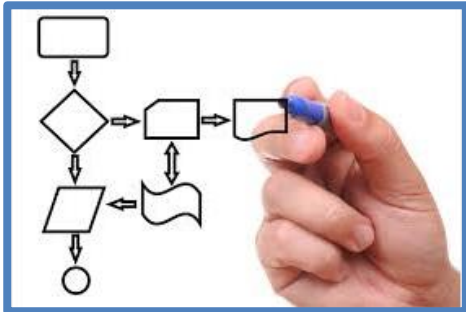
<https://iotnewsletter.org>



What is Product Cyber?



People



Process



Technology

Process *fundamentals*



know your **Inventory**



Assess your risk



Remediate your vulnerabilities



Disclose your solutions

What should keep you up at night.....



Turning the Tables

- Age of automation and analytics is upon us
- Benefits are real and stakes are high
- Double-edged sword of digitization
- Expanding digital touchpoints
- Engineering done correctly can reduce risk

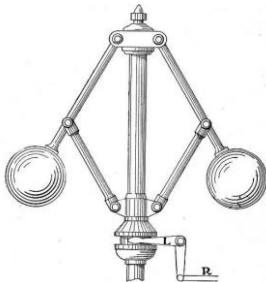


Product Cyber...*Controlling in a Connected world*

Why Now...

- Big Data and Decision Support
- Exponential Technology Growth
- Scale drives responsibility w Customers

Product
Technology



Flyball Governor
Mechanical



Mark II
Analog



Mark VI
Digital



Cloud
Internet of Things

Connectivity

Exposure	Single turbine	Multiple turbines	Power Plant	Installed Base
Access Security	Machine Room	Electrical Room	Control Room	The World
	Door	Keys	Badge Reader	FW, Encrypt, Harden

Why IT & OT.....

Information Technology (IT)

Security is about ***the data***.....

Priorities.... CIA

- *confidentiality*
- *integrity*
- *availability*



Protection

- Spear Phishing
- Social Networking
- Malware

IBM, Palo Alto, Cisco...



Operation Technology (OT)

Security is about ***critical infrastructure***.....

Priorities.... AIC

- *availability*
- *integrity*
- *confidentiality*



Protection/Inspection

- Network Traffic inspection
- ICS Signature & Protocols
- Policy Reporting

Wurldtech, Cisco....



Conflicting technical priorities, common protection goals

Sophisticated attacks on Critical Infrastructure

Stuxnet

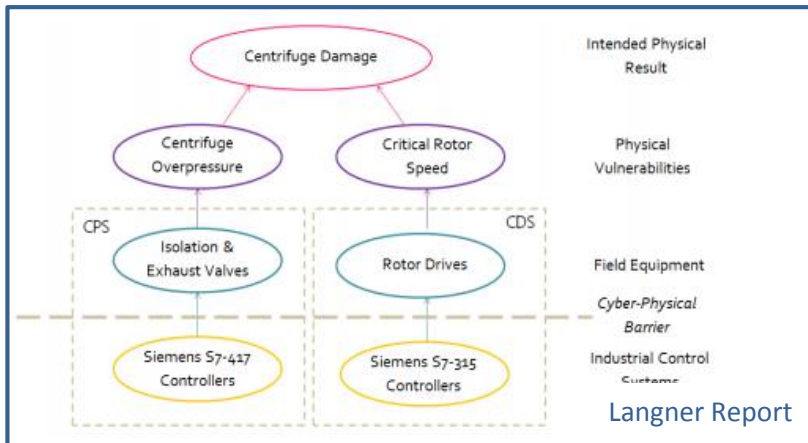
- Destroy Iranian centrifuges
- Test/Learn while going undetected
- Alter approach based on learning, physics
- **Mask Operation**



Natanz uranium enrichment facility

Centrifuge Physics of Failure

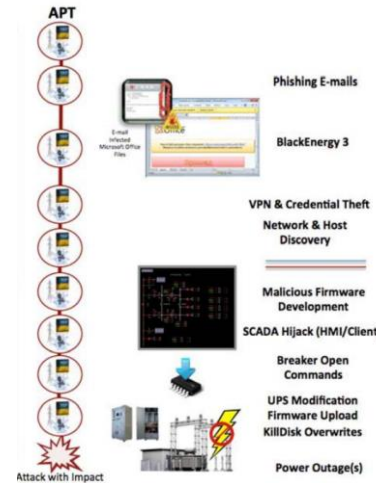
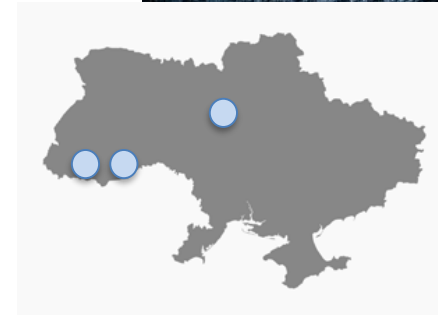
- Over Pressure
- Speed/Frequency



Ukraine Power Grid

Coordinated attack

- (3) locations, Utilities
- Customer Phone Center



Kill Chain Mapping (SANS)

- In Systems Over 6 months
- Collecting data
- IT to OT lateral movements
- **Masking Operations**
- Wiping Files
- **Jaming Call-Centers**
- **Power Out**

Well Known....*but not alone....*

OT Security, what do we do?

OT Security Challenges

- Legacy Equipment
- Educational / Cultural
- Weak infrastructure



Start with the Fundamentals

- Defense in Depth - Layered Protection
- Know your inventory & risks
- Minimize your attack surface

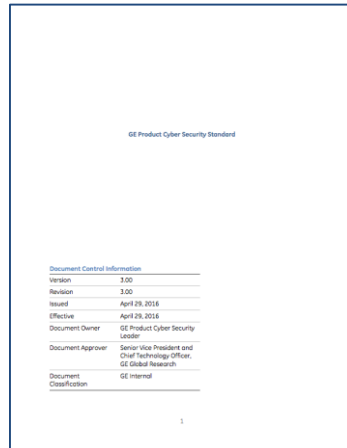
Fundamentals tied to Programs and Culture

How do we sleep at night.....



GE Standards & Policies

GE Product Cyber Standard



Corporate

- Roles & Responsibilities
- Training
- Risk
- Security
- Communications
- Response

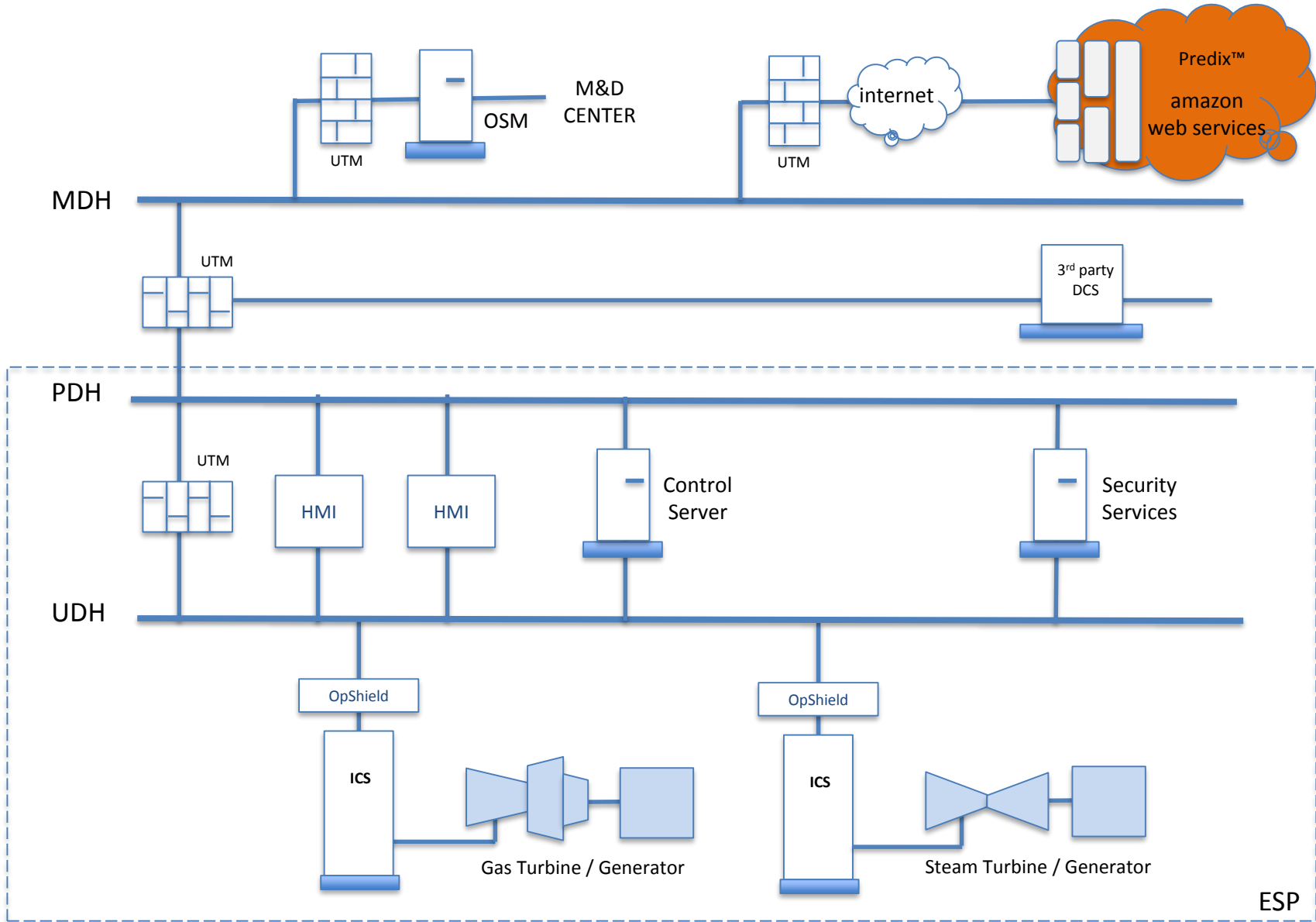
GE Power ePOL-705



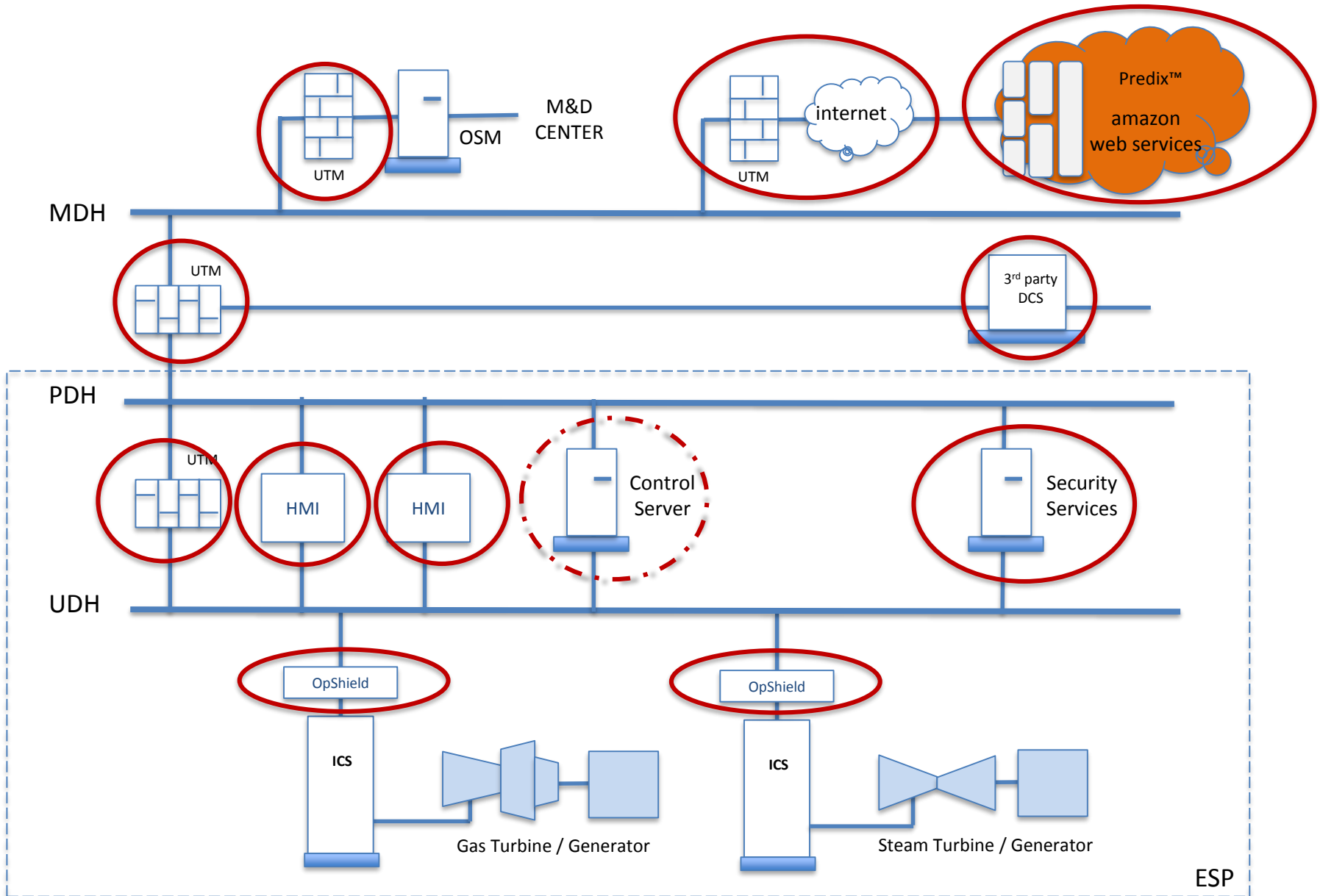
Business

- Roles & Responsibilities
- Inventory
- Risk Assessments
- Risk Categorization
- Remediation
- Incident Response

Power Plant Reference Network Architecture



Power Plant Reference Network Architecture



OpShield from Wurldtech Securities

- OT Specific Signatures
- Deep Packet Inspection
- Network Whitelist
- Network Segmentation

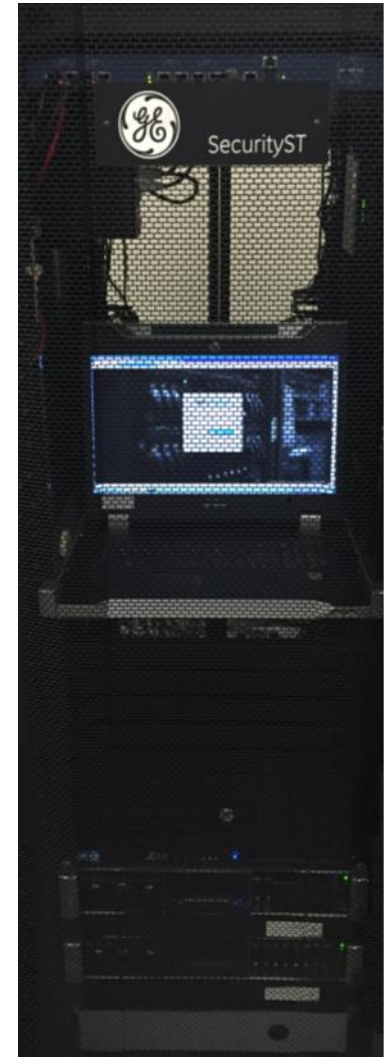


 **OPSHIELD**

Security*ST

Centralized management security system for the Mark VIe Control System

- Intrusion detection
- Role based Access Control
- Password Management
- Public Key Infrastructure
- Centralized Antivirus
- Software Update
- Backup & Recovery

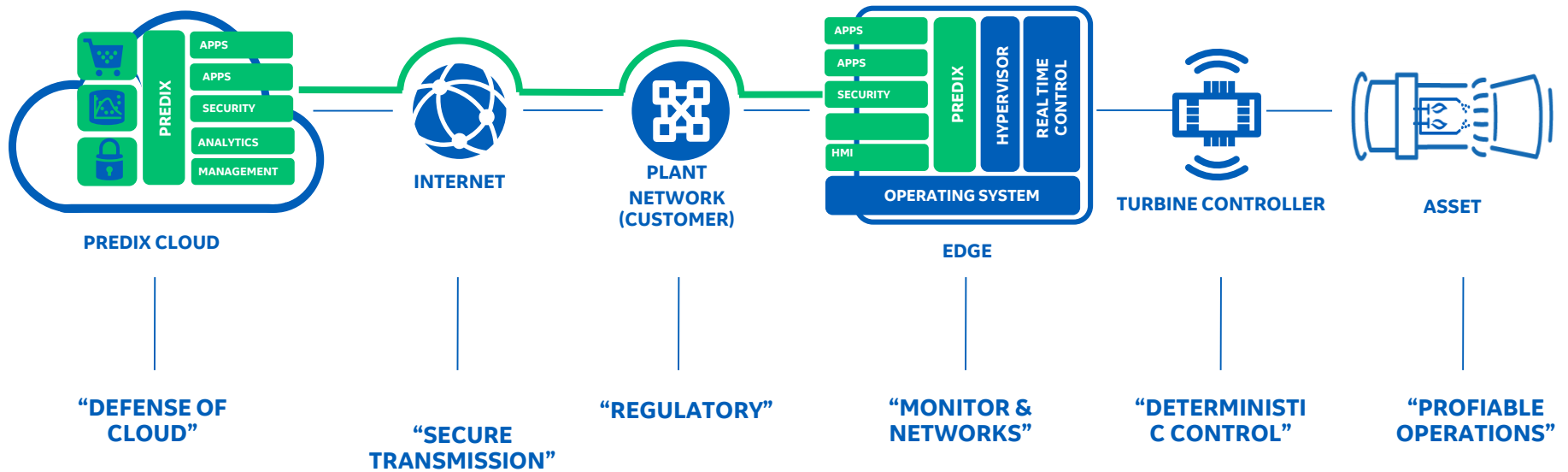


Next Technology Steps

...transitioning to a *Secure* Server based controls architecture.....

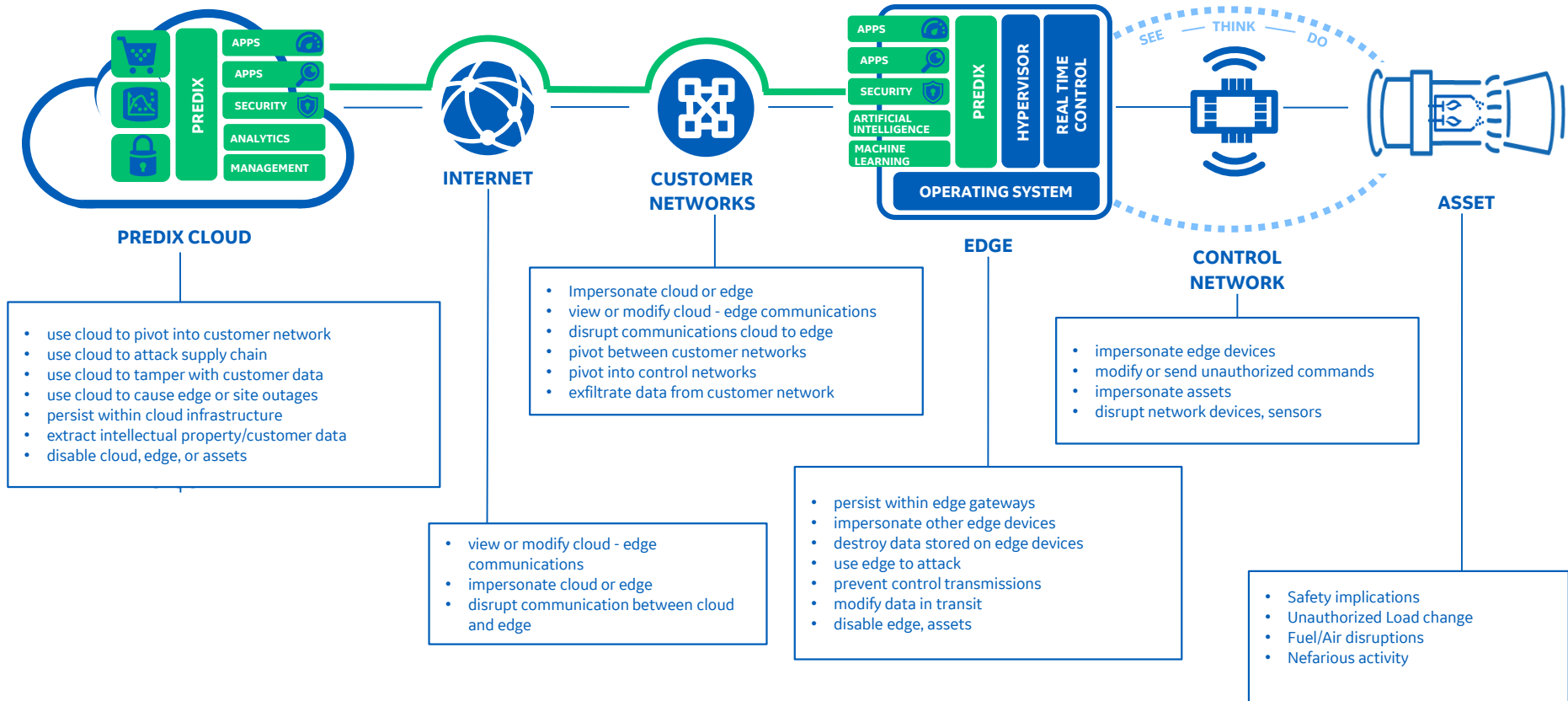
Cloud to Asset

GE Power Ecosystem Objectives

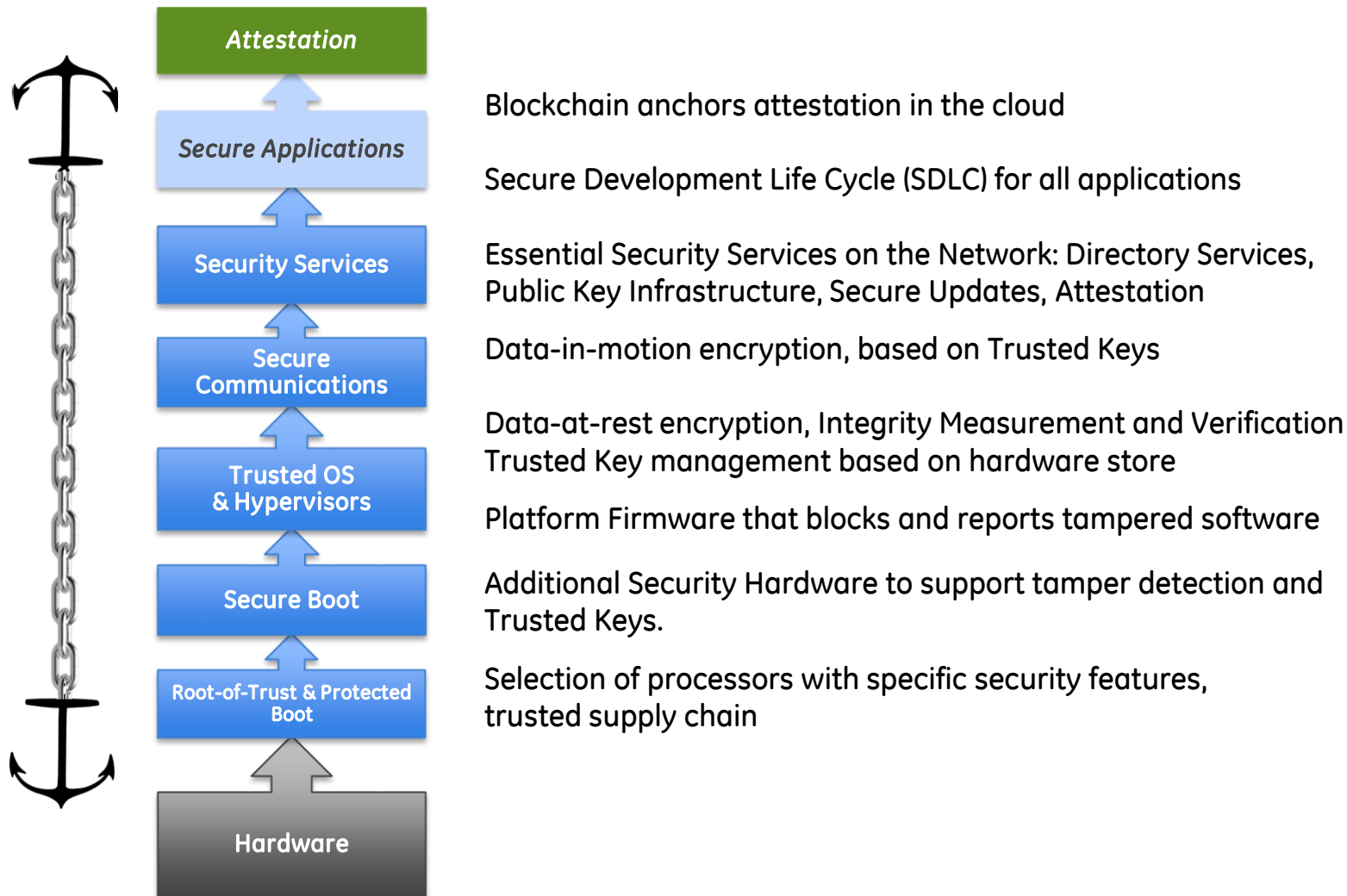


Cloud to Asset

ATTACKER OBJECTIVES (Threat Model)



Chain-of-Trust



Leadership of the Future

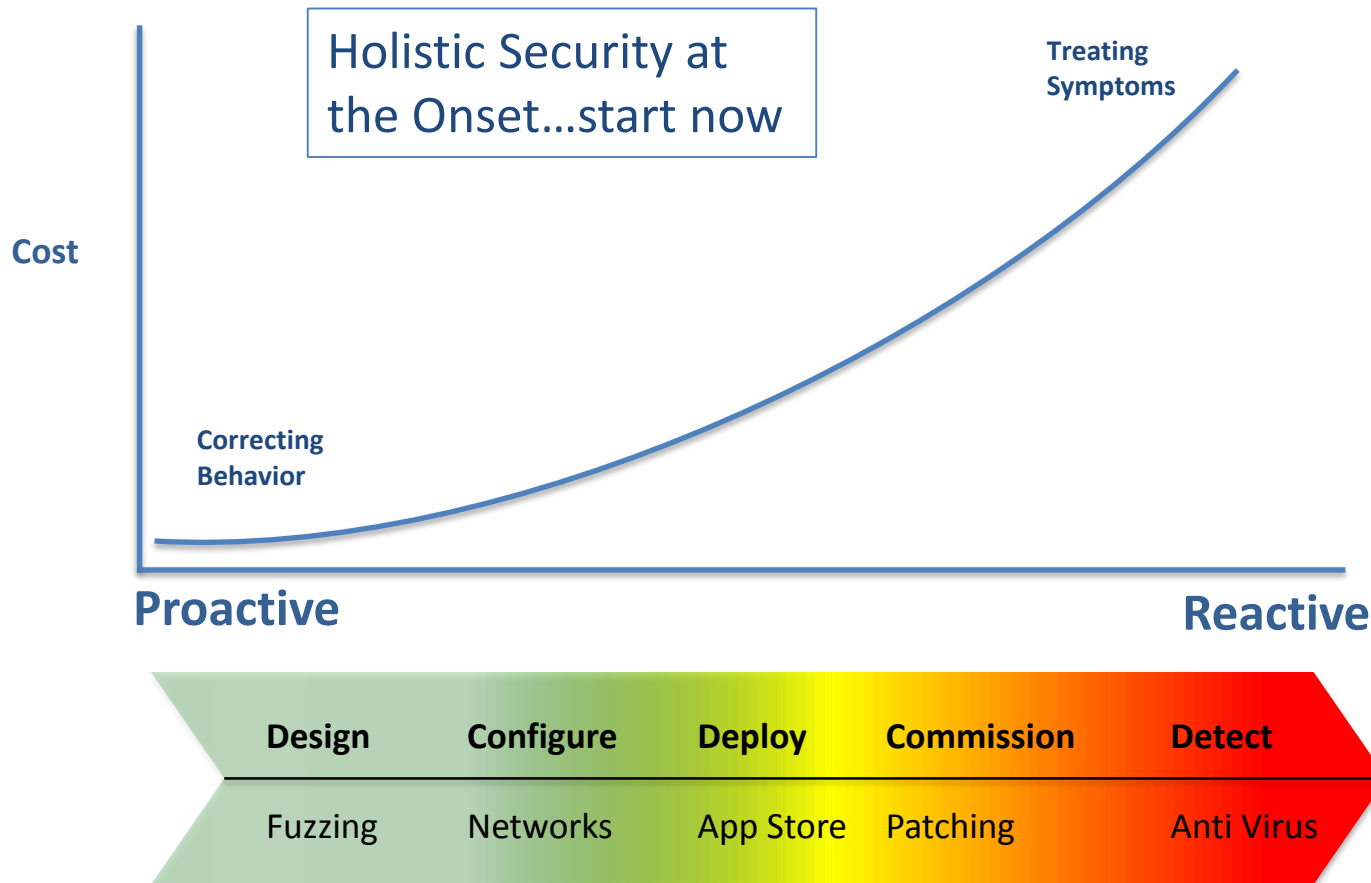
...tomorrow's leaders will have digital/security DNA.....

JRI DLM '17

...tomorrow's leaders, HR, Finance, Engineering, Business will come from DT....

Jim Fowler, VP, DLM '17

Security Development – cost lifecycle



Design begins with Security.....

Secure by Design

1. TRAINING	2. REQUIREMENTS	3. DESIGN	4. IMPLEMENTATION	5. VERIFICATION	6. RELEASE	7. RESPONSE
1. Core Security Training	2. Establish Security Requirements	5. Establish Design Requirements	8. Use Approved Tools	11. Perform Dynamic Analysis	14. Create an Incident Response Plan	Execute Incident Response Plan
	3. Create Quality Gates/Bug Bars	6. Perform Attack Surface Analysis/Reduction	9. Deprecate Unsafe Functions	12. Perform Fuzz Testing	15. Conduct Final Security Review	
	4. Perform Security and Privacy Risk Assessments	7. Use Threat Modeling	10. Perform Static Analysis	13. Conduct Attack Surface Review	16. Certify Release and Archive	

Why

- Differentiate GE
- Customer Expectation
- Cost to Fix vs Catch
- Personal Toolkit
- Make SW Dev Fun
- It's a requirement @GE

Where

The screenshot displays the 'Secure Development Training' website. At the top, it says 'Show recommended courses based on:' followed by a list of course categories: 'Full Web-Based Curriculum', 'Get Dev Operations For Compliance', 'SAC App Sec Prio Compliance', and 'Lightning Courses'. Below this, there are three course cards:

- Fundamentals of Application Security (1-Year Recurrence)**: SECOP-APPSEC-AWA-101-R-80000R_CABR. Pre-Requirement: None. Course Duration: 80 minutes. Register Now.
- Software Security Awareness (1-Year Recurrence)**: SECOP-APPSEC-AWA-102-R-80000R_CABR. Pre-Requirement: None. Course Duration: 80 minutes. Register Now.
- Fundamentals of Secure Development**: SECOP-APPSEC-CSD-101-80000R. Pre-Requirement: AWA-101. Course Duration: 80 minutes. Register Now.

<http://sps.ge.com/sdt.htm>

<https://www.microsoft.com/en-us/SDL/process/response.aspx>

Security Captains

What's a
Security
Captain ?

Threats



Security Captains



Will Garcia



John Raffensberger



Michael Vaughan



Charlie Belmer



Matt Page



Threats



Secure SW Dev
Learning Leaders

How do I get involved??

GE Power – Digital Technology Biz of the Year!

Jan 27, 2017 Source: GE Power News

At the recent Digital Technology meeting held in Arizona, Jim Fowler, CIO – GE, named **GE Power as Business of the Year!** The GE Power Digital Technology leadership team accepted the award on behalf of the entire function.



The GE Power Digital Technology team is pictured receiving the Business of the Year Award from GE's CIO, Jim Fowler.

- Be a part of something BIG!!
- Our Chairmen says
“ We are defining what digital means in an industrial world, translating data to outcomes and revolutionizing GE to improve how the world works. Together, we work to build the future.”
- This is part of your role and a skillset that critical.
- 1400 Security roles added in Budapest
- Cyber Security experience is a competency that roles will require in the future!

Leadership Program : EEDP (TLP D/D, EEP)
What type of submission is this? : Assignment
Job/Project Title : Controls - Predix Development - (2 available) (multiple locations)
Business Unit : GE Power
Primary Work Address : 300 Garlington Road Greenville SC
Region : United States
Sub-Functional Area : Computer Science/Software Engineering
Functional Capabilities :

- Systems Engineering
- Digital Thread
- Control Systems
- Smart Machines and Sensors
- Product Design
- Fast Track
- Cyber Security



Now What?

*bookmark....*Product Security support central

*reference.....*OT Cyber Blueprint

*join....*Yammer Product Security Group

*do.....*Read more, Ask Questions